

Swiggy asks for all your data with one tap. DPDP says that consent is invalid.

Focus: the onboarding consent experience — the first legal touchpoint where personal-data collection is authorized.

THE PROBLEM

Swiggy's onboarding bundles essential delivery data (phone, address) with optional behavioural data (location, marketing, analytics) behind a single 'Accept All'. DPDP Act, Section 6 requires consent that is free, specific, informed, unconditional and affirmative — bundling is none of these.

THE SOLUTION — SWIGGY SARAL

Swiggy SARAL: unbundled consent buckets, just-in-time micro-notices, a multilingual plain-language layer, an immutable Consent Ledger, and a children's-data gateway.

1 Unbundled buckets

2 Just-in-time notices

3 Multilingual

4 Consent Ledger

5 Kids gateway

DECISION ASK Approve resourcing + Phase-1 A/B launch to make consent valid without breaking onboarding.

EVIDENCE LEDGER

~24M+

Monthly active users

₹250 cr

Max DPDP penalty

~68% of digital natives

Value data transparency

None (S.9 gap)

Children's-data gate today

Three people, one broken consent moment

The person whose data is at stake — and why the current flow fails each of them.

Priya, 28 • Bangalore

Privacy-conscious urban diner

Context: Lunch 3×/week; Instamart on weekends.

Mental model: Gets that Swiggy needs address + phone. Doesn't get why it tracks location when closed, or sends Dineout emails after biryani.

Attitude: Shares for clear value; hates dark patterns.

If we fail: Churns to Zomato.

Ramesh, 42 • Tier-2

Low-literacy, trust-first

Context: First smartphone; weekend family dinners; speaks Kannada.

Mental model: Doesn't read policies; taps 'OK' to reach food faster.

Attitude: Trusts by default; needs protecting from rapid-tap habit.

If we fail: Silent churn.

Ananya, 16 • Student

Digital-native minor (child user)

Context: Snacks after tuition; parent pays via UPI.

Mental model: Unaware her location + browsing is collected; guardian has no visibility.

Attitude: N/A — duty of protection is on the platform (S.9).

If we fail: ₹250 cr tier + guardian uninstall.

PAIN POINTS TODAY

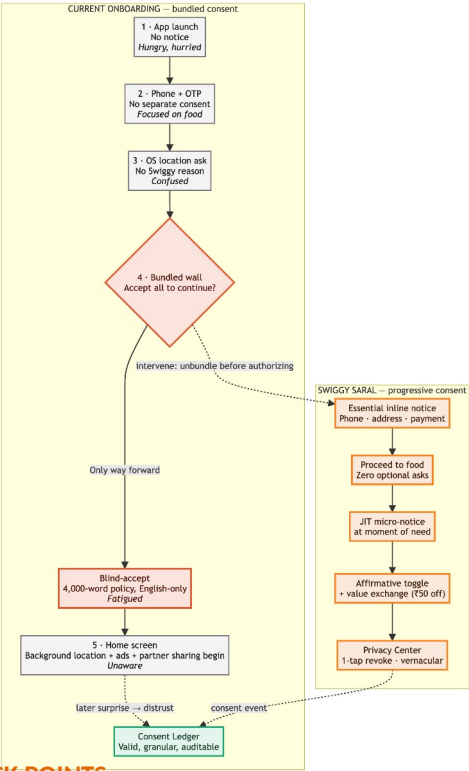
- Consent fatigue — 4,000-word policy → abandon or blind-accept
- Dark-pattern anxiety — pre-ticked box, 'agree to continue'
- Vernacular gap — English-only excludes 60%+ users
- No memory — can't recall or revoke consent
- Parental blindspot — no mechanism for minors

WHY IT MATTERS

For Priya, bad consent UX = switch. For Ramesh = silent churn. For Ananya's parent = uninstall + social post.

The 'wall of text' onboarding breaks the law before the first order

How Swiggy collects data today (stated assumptions) and where it fails DPDP.



FRICION & RISK POINTS

Legal: DPB show-cause on enforcement

Conversion: ~18% drop at Terms wall (Tier-2/3)

Trust: privacy = #2 complaint (Swiggy One)

Competitive: Zomato piloting granular toggles

Current state → gap analysis

WHERE IT FAILS DPDP

DPDP principle	Current state	Sev
Free & unconditional (S.6)	Can't proceed without accepting all	Critical
Specific & informed (S.6)	One statement covers 12+ activities	Critical
Children's data (S.9)	No age gate, no parental flow	Critical
Affirmative action (S.6)	Pre-ticked marketing box	High
Purpose limitation (S.5)	OTP phone reused for marketing	High
Right to withdraw (S.7)	Email-only, no in-app control	High
Data minimisation (S.4)	24/7 background location	Medium

PROPOSED SOLUTION

Swiggy SARAL — consent as a product feature, not a legal tax

Simple · Accessible · Rational · Actionable · Legal. From all-or-nothing to just-in-time, just-enough, just-for-now.

FIVE PILLARS

1 • Unbundled buckets

Essential (inline, no opt-out) vs Optional (granular, un-ticked toggles).

2 • Just-in-time notices

Ask at the moment of need + value exchange (₹50 off for WhatsApp alerts).

3 • Multilingual plain-language

12 languages, 8th-grade reading level, icon per data category.

4 • Consent Ledger

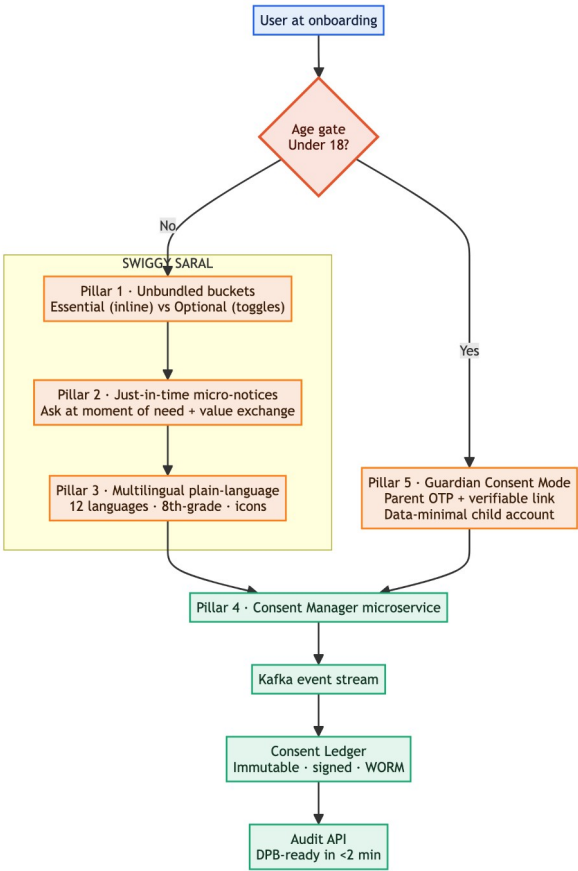
Immutable signed log; DPB-auditable in <2 min. Kafka → WORM → Audit API.

5 • Children's gateway

Age gate → Guardian Consent Mode; child account runs data-minimal.

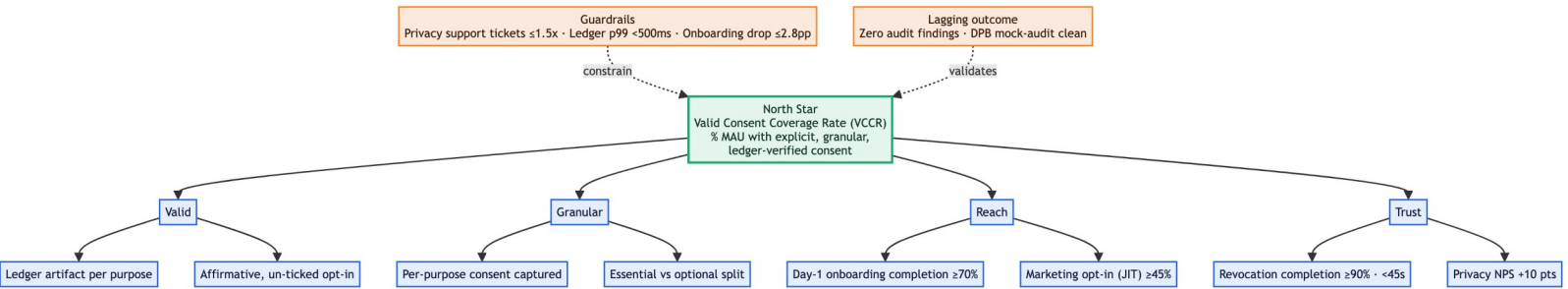
WHY NOT THE ALTERNATIVES

Alternative	Rejected because
Single-page granular checklist at signup	~18% drop-off; violates low-patience context
Post-first-order consent prompt	Loses new-user personalization window
OS permissions only	Fails DPDP purpose-specific notice
Third-party consent plug-in	Vendor lock-in; weak vernacular UX



One North Star that fuses compliance, conversion and trust

Valid Consent Coverage Rate — high VCCR means legally protected AND users aren't bouncing.



★ NORTH STAR METRIC

Valid Consent Coverage Rate (VCCR)

% of MAU with explicit, granular, unbundled, ledger-verified consent for every active processing purpose.

Target: ≥95% within 90 days

SUPPORTING METRICS

Metric	Baseline	Target
Day-1 onboarding completion	72%	≥70% (≤2.8pp drop)
Marketing opt-in (post-JIT)	100% bundled	≥45% in 60 days
Consent revocation completion	n/a (email only)	≥90% · median <45s

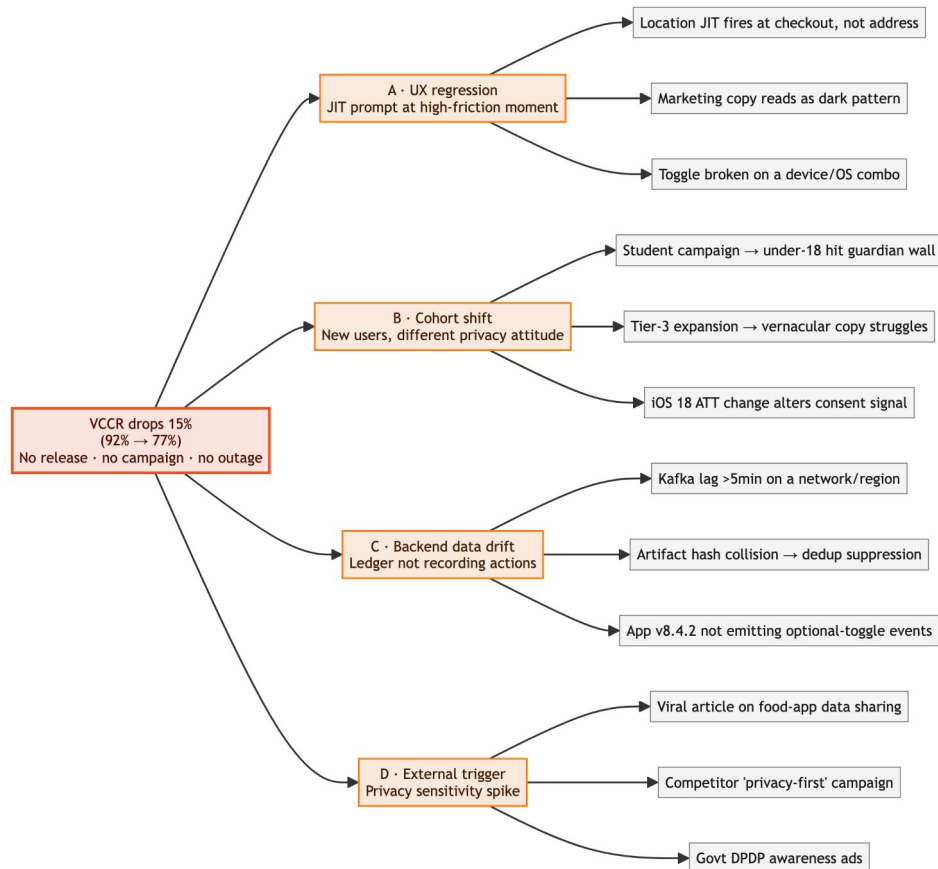
GUARDRAILS Privacy support tickets: ≤1.5× baseline · Ledger sync latency (p99): <500ms

SUCCESS CRITERIA

- ✓ Compliance: zero audit findings; passes DPB mock audit
- ✓ Trust: Privacy NPS +10 pts
- ✓ Business: onboarding within 3pp; opt-in >40%
- ✓ Ops: 100% real-time ledger sync, zero data loss / 30d

If VCCR drops 15% with no release — a forensic, not a panic

Scenario: 3 weeks post-launch VCCR falls 92% → 77%. No release, campaign, or outage.



DATA ANALYSIS PLAN

- Segment drop by platform / app version / OS → isolate iOS-only vs version bug
- Funnel drop-off by consent category → marketing-only (JIT) vs uniform (cohort/external)
- Ledger event volume vs app analytics volume → backend data loss
- Correlate with acquisition source / campaign ID → cohort shift
- Social listening 'Swiggy + privacy' → external trigger
- Session recordings at consent screens → rage-click / UX confusion

ROOT-CAUSE METHOD

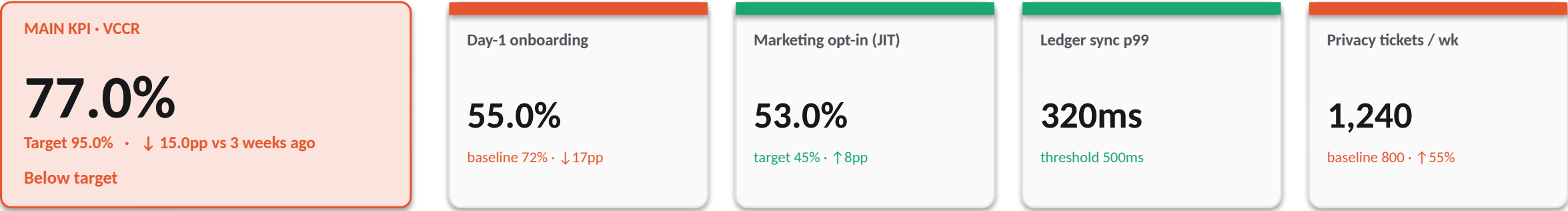
Five-Whys + cohort isolation. Example: opt-in fell → JIT fires at checkout → address event mis-mapped to checkout in v8.4.2 → release regression in trigger logic.

NEXT STEPS

- 0-24h: freeze rollout if <80%, verify pipeline, alert legal
- 1-7d: A/B JIT timing, hotfix regression, in-app survey
- 7-30d: re-engage incomplete consent, fix micro-copy, transparency post

Consent Health Command Center

Real-time monitoring of compliance, conversion and trust (mock data, 30-sec rollup).



SEGMENTATION — platform × geography × cohort

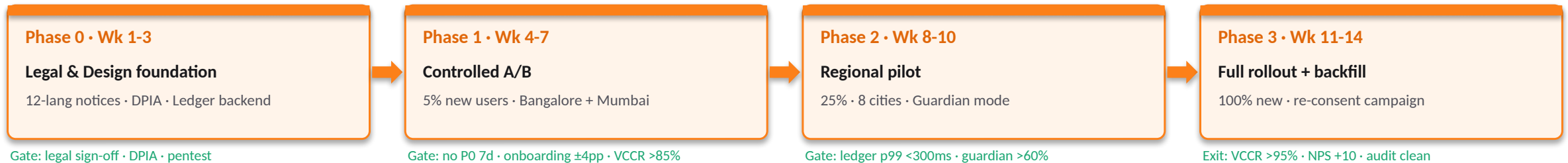
Segment	VCCR	Onboard	Opt-in	Note
iOS / Metro / New (Jun)	68%	48%	58%	Highest drop; iOS 18 ATT suspected
Android / Metro / New	82%	62%	52%	Within guardrail
Android / Tier-2 / All	79%	58%	44%	Vernacular copy tests needed
iOS / Tier-1 / Returning	94%	n/a	61%	Re-consent successful
Guardian / Under-18	45%	35%	12%	Parental OTP friction high

ALERT RULES

- ▶ VCCR <80% >2h → P0 auto-freeze + page SRE + notify Legal
- ▶ Onboarding <60% >6h → P1 fallback simplified flow
- ▶ Ledger p99 >500ms >10m → P1 Kafka lag
- ▶ Privacy tickets >1.5× 3d → P2 copy review

Phased, validated, reversible — and we never A/B-test illegality

From legal foundation to full rollout with hard gates at each phase.



A/B TESTABLE

- JIT prompt timing
- Toggle UI pattern
- Incentive framing
- Vernacular variants (formal vs colloquial)

NEVER A/B-TESTED

- Essential-data notice (legally mandated)
- Children's age gate
- Consent Ledger logging

Compliance shadow test: For mandatory elements run 'compliance shadow tests': new notice to 100% of a cohort vs a holdback that sees the OLD compliant notice — never a non-compliant one.

VALIDATION METHODS

- Quant: funnel, cohort retention, VCCR trend
- Qual: moderated tests in Hindi/Tamil/Kannada
- Legal: external DPDP mock audit every 2 weeks
- Tech: chaos test Ledger (Kafka outage → fallback queue)

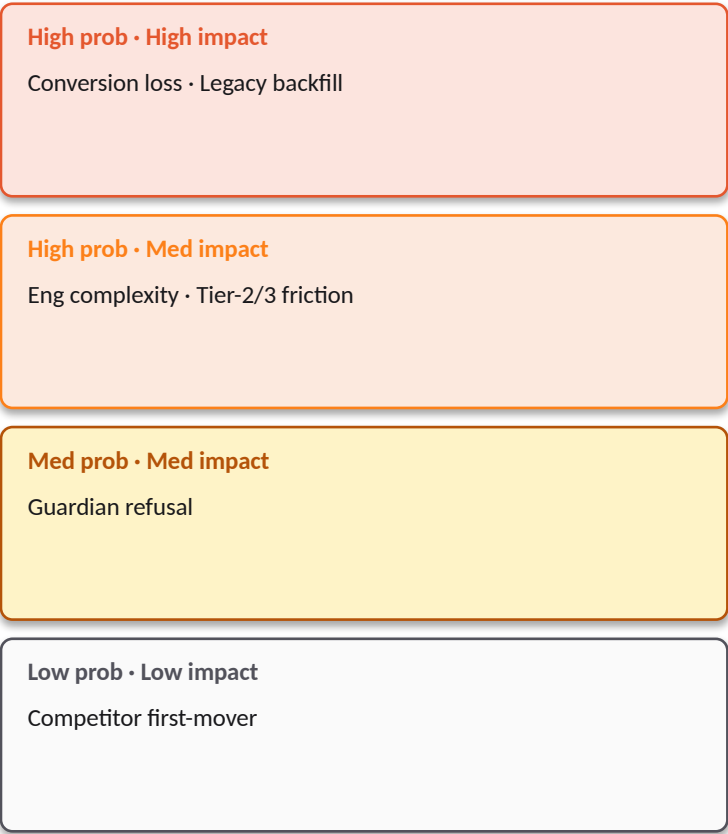
Honest accounting of what we trade for compliance

We know conversion will hurt and legacy data is messy — the cost of inaction is existential.

RISK REGISTER

Risk	Impact	Prob	Mitigation → Trade-off
Engineering complexity	High	Certain	Managed Kafka + WORM S3; 2 senior eng / 8 wks; in-memory fallback → Accept 3-wk backend extension vs lifetime liability
Business (conversion)	High	Likely	JIT incentives; first-party personalization; re-engage opt-ins → 6 mo lower ad revenue for defensible model
User friction (Tier-2/3)	Medium	Likely	Progressive disclosure; <30s consent; Quick-Start auto-deny → Small top-funnel loss for trust + retention
Edge: declines all optional	Medium	Certain (some %)	Minimal mode: manual address, no marketing, aggregated analytics, blocked sharing → Higher eng cost for privacy mode
Edge: non-cooperative guardian	Low	Possible	Limited-access order, zero retention, parent education → Lose some under-18 volume vs S.9 penalty
Edge: legacy data backfill	High	Certain	'Trust Refresh' re-consent; purge >12mo profiles; document legitimate use → Temp. data-richness loss to cleanse liability

RISK HEATMAP



CONCLUSION

Privacy as a product, not a penalty

SARAL turns DPDP compliance into a competitive advantage — legal safety, business growth, user trust, at once.

Legal safety

Zero bundled consent · verifiable ledger · parental gateway · audit-ready <2 min

Business growth

Core onboarding unblocked · opt-in recovered via JIT · premium trust positioning

User trust

Plain-language multilingual notices · one-tap revocation · transparent usage

DECISION ASK Approve today: (1) 2 senior backend eng + 1 designer + 1 legal PM for 12 weeks; (2) ₹45 lakh for translation, audit & managed infra; (3) Go for Phase-1 A/B on 20 July 2026.

IMMEDIATE NEXT STEPS

Owner	Action	Due
Product	PRD for Consent Ledger + JIT trigger logic	10 Jul
Engineering	Staging for SARAL backend + variants	17 Jul
Legal	Complete DPIA → DPO sign-off	15 Jul
Design	Hi-fi prototypes + vernacular copy	12 Jul
Growth	Incentive framework for JIT opt-in	14 Jul

DPDP isn't a deadline to fear — it's a blueprint for the most trusted food-tech platform in India. Our users' data belongs to them; their trust belongs to us.